

praisonai-platform: JWT signing key defaults to hardcoded "dev-secret-change-me", allowing token forgery for any user when PLATFORM_ENV is unset

Report Type: Weekly · Generated: May 31, 2026 16:17 UTC · Coverage: May 29 – May 31, 2026

1	1	0	0
Total Advisories	Critical	High	Medium

Executive Summary

Summary **Type:** Insecure default cryptographic key. The JWT signing secret defaults to the hardcoded literal `"dev-secret-change-me"` when `PLATFORM_JWT_SECRET` is unset. A safety check exists but only fires when `PLATFORM_ENV != "dev"`; the default value of `PLATFORM_ENV` is `"dev"`, so the check is silently bypassed in any deployment that does not explicitly opt out. The attacker reads the literal from this public source file, mints a JWT with arbitrary `sub` and `email` claims, and authenticates as any existing user (including workspace owners and admins). **File:** `src/praisonai-platform/praisonai_platform/services/auth_service.py`, lines 25-36 and 114-137. **Root cause:** the production-mode guard checks `os.environ.get("PLATFORM_ENV", "dev") != "dev"` — but the default is `"dev"`, so a clean deployment that just imports the package and runs `uvicorn praisonai_platform.api.app:app` proceeds with the hardcoded secret. The package documentation does not warn loudly enough tha

CONFIDENTIALITY NOTICE: This report is classified PRO tier and intended exclusively for the named recipient. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited. © 2026 CYBERDUDEBIVASH SENTINEL APEX. All rights reserved.

Top Threat Advisories

High-priority advisories ranked by CVSS score, exploitability, and actor attribution.

Advisory Title	Severity	CVSS	EPSS	AI Summary
praisonai-platform: JWT signing key defaults to hardcoded "dev-secret-change-me"	Critical	9.8	—	## Summary **Type:** Insecure default cryptographic key. The JWT signing

MITRE ATT&CK;® Coverage

ATT&CK; technique density score: 0.0 · Techniques observed: 0 · Tactics covered: 0

Threat Actor Intelligence

Attribution analysis across advisories in this report period.

Threat Actor	Advisory Count	Associated CVEs / Indicators
CDB-UNATTR-CVE	1	—

Actionable Recommendations

Prioritized defensive actions based on this period's intelligence.

1. Apply patches immediately for praisonai-platform: JWT signing key defaults to hardcoded "dev-secret-change-me", allowing token forgery for any user when PLATFORM_ENV is unset.
2. Enable enhanced monitoring for related IOCs.
3. Review SIEM rules for associated MITRE ATT&CK; techniques.

Appendix — Report Metadata & Legal

Field	Value
Report ID	intel--f78bbf11047c296d920871c2
Report Type	Weekly
Platform	CYBERDUDEBIVASH SENTINEL APEX v143.0.0 GOD-MODE
Generated At	2026-05-31T16:17:22.663392+00:00
Customer Tier	PRO
Customer Email	—
TLP	TLP:CLEAR
STIX Version	2.1
ATT&CK Version	v15

Legal & Usage Notice

This threat intelligence report is produced by CYBERDUDEBIVASH SENTINEL APEX, operated by Bivash Nath (GSTIN: 21ARKPN8270G1ZP). All intelligence is aggregated from public vulnerability databases (NVD, CVSS), threat feeds, and proprietary AI enrichment pipelines. This report is provided AS-IS for informational and defensive security purposes only. CYBERDUDEBIVASH accepts no liability for actions taken based on this intelligence. Redistribution, resale, or disclosure to unauthorized parties is strictly prohibited without written consent. For licensing inquiries contact bivash@cyberdudebivash.com.